Critical Infrastructure Security

IY5612 (IY3612/IY4612) — Academic Year 2024/2025 (Unit 7)

Stephen D. Wolthusen
stephen.wolthusen@rhul.ac.uk

Department of Information Security and Communication Technology
Norwegian University of Science and Technology, Norway

and

Department of Information Security
Royal Holloway, University of London, United Kingdom

Unit 7— SCADA and DCS Systems

Contents

SCADA and DCS Systems

SCADA and DCS Systems
- Introduction
- Introduction to SCADA Architectures
- Distributed Control Systems
- Control System Protocols

State Estimation

Security of Control Systems Components

Part I

SCADA and DCS Systems

SCADA and DCS Systems

In this block we introduce further aspects of cyber-physical systems:

- Introduction to Supervisory Control and Data Acquisition (SCADA) architectures
- Distributed Control Systems
- Control System Protocols

Recommended Reading (1)

- K. Stoufer, J. Falco, K. Scarfone:
  NIST Special Publication 800-82 Rev. 3: Guide to Industrial Control Systems (ICS) Security
  U.S. National Institute of Standards and Technology (Sep. 2023)

  Chapters 2 and 3 (as in Unit 4)

Beyond Isolated Control Systems

Traditional control systems were widespread until the 1990s and characterised by

- Dedicated console systems
- PLC and RTU systems with point-to-point communication
- HMI components were directly associated with the control system

However, this implied a number of drawbacks:

- No ability to provide remote diagnostics
- No remote access to control systems
- Limits to size and scale of control systems
- No information flows to (and from) business systems to control and field systems

Control Systems Evolution (1)

Distributed control has undergone several evolutionary phases — although these co-exist since old systems are often only replaced at the end of the lifetime of the system they control: **First Generation** systems relying on analog POTS lines (dial-up or usually leased-line), radio, or microwave links for alerts from sensors and limited interaction owing to very modest bandwidth

Such systems had very limited security mechanisms, relying on obscurity or leased lines

- Data transmission was often via FSK signals
- Leased lines are not a strong security feature against modestly competent adversaries: Physical wiretapping is straightforward, particularly in more remote locations — and even in confined areas, TSCM is difficult without the added interference of physical plant equipment

Control Systems Evolution (2)

Second Generation systems still in widespread use

- Still relying mostly on POTS and microwave links for wide-area connections
- Leased lines can guarantee response times and do not require circuit set-up where required
- Proprietary protocols (not IP-based), often via modem connections
- Encryption has been endorsed only in recent years, problems with limited bandwidth (kBit/s) and key management limit viable options
- Retrofitting security mechanisms is often only possible as a "*bump in the wire*" without changing remaining systems
- Identification and authentication of endpoints and legitimate operators, field technicians usually relied on widely-known, rarely changed passwords

Control Systems Evolution (3)

Current or **third generation** systems rely increasingly on open communications architectures

- Ethernet-based networks for field and control networks
- Widespread use of IP-based protocols
- Ability to construct large-scale and high-capacity networks offers much greater flexibility, but also increases potential for attacks
- Protocols and architectures used are often translated from the more closed, proprietary environment

Cyber Security risks are arising mainly (but not exclusively) from third-generation systems and their close integration

Beyond Isolated Control Systems

Recall that PLC systems have a number of limitations particularly for larger installations:

- Geographic extent is restricted (at least in case of simple field links and field buses) — this can also be overcome by RTU units
- Capacity of PLC for number of sensors and actuators may be large but is ultimately also limited

While a single PLC may be able to control completely different components such as machines, this does not scale to larger installations

- Desire for robustness (against failures or attacks) makes redundancy highly desirable

Larger installations will hence not be content with single or non-connected PLCs and SCADA environments

Distributed Control Systems (1)

Distributed Control Systems (DCS) divide the functions of SCADA systems up into a number of layers typically forming a hierarchy:

- At the lowest level, sensors and actuators are interconnected via field bus systems
- The field bus (utilising different technologies, but typically non-routable specialised protocols) will be controlled by local PLCs, connected to RTUs, or intermediate nodes

Intermediate nodes can be field bus aggregators acting only to translate protocols, or SCADA servers

- SCADA servers (also known as Master Terminal Units (MTU)) logically group and control a number of lower-level components
- This allows higher-level DCS layers some level of abstraction

Distributed Control Systems (2)

Immediate control requiring fast and guaranteed cycle times will be handled locally by the PLC/RTU

- The higher-level units cannot provide this guarantee owing to communication delays or less reliable communication channels
- SCADA MTU may also be connected through some form of wide-area networks (WAN)
- WAN implementations and protocols vary, but increasingly IP-based protocols are used even where dedicated or leased lines are in use

Even if normal control is exerted centrally, there is typically some form of local control or operation possible, e.g. for maintenance or in case of emergencies

Distributed Control Systems (3)

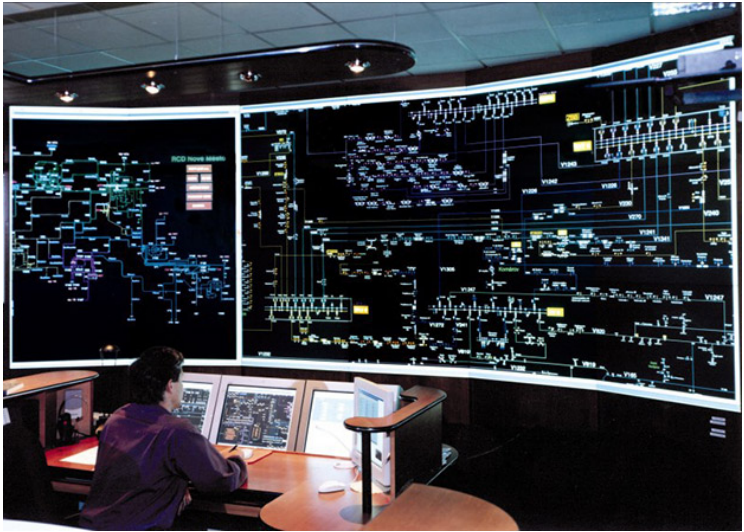
SCADA MTUs and network links can be provided redundantly, but will typically be interconnected via standard TCP/IP networks

- These networks need not be connected to the Internet itself — and systems on these network will often be difficult to harden against cyber security threats even with standard operating system patches
- The intermediate layer(s) will not only house the MTU(s), but also be home to components such as the overall HMI, Data Historian Database for the overall system, and some other workstations

Note that for all practical purposes the process control network is a "standard" network — the distinction is purely logical and based on its role, not on any particular technology

Distributed Control System

Control Room (HMI)



Network Interconnection

It will frequently be desirable to link process control networks to general (“business”) networks:

- Information flows from the DCS will help assessing whether production goals are met, problems are encountered, etc.
- However, it is also desirable to provide information *to* the process control network:
  - Management Information Systems (MIS) and Enterprise Resource Planning (ERP) systems invariably interact with such processes

Enforcing separation between process control and regular networks is hence difficult to enforce unless a very strong (typically regulatory) case is made

Control System Protocols

Protocols used vary depending on the layer in the control system used:

- From the MTU layer on upwards, these may be vendor-specific, but will be encapsulated in standard protocols (HTTP, hopefully HTTPS)
- This may be further nested e.g. by virtualisation of HMI consoles that are then run on a single hardware platform and made accessible via common protocols such as RDP (Remote Desktop Protocol)
- Standards exist for field bus systems, but in a wide variety — there exists no single field-bus standard

Many protocols fulfill several purposes, both for immediate read/write access to field devices and PLC/RTU, but also to program these

A Simple Field Bus Protocol: Modbus

Modbus was developed in the late 1970s for PLC communication and is still very widely used

- The protocol is extremely simple and royalty-free, making it attractive to other vendors
- A number of variants exist for different transport mechanisms, mainly distinguishing between direct OSI layer 1/2 (serial, Ethernet) and layer 3/4 (TCP/IP) support

The simplest and most common variant is called **Modbus RTU** (used for serial communication) using a binary representation, with a variant **Modbus ASCII** also used for serial communication using an ASCII encoding

- Only the master can initiate a command, but there is no explicit identification and authentication
- The master identifies the target device targeted for a command via a unique station address

Modbus (2)

All communication is initiated by the master:

- Each session starts with a Function Code and Data Request sent by the unique master (this is called a **Request PDU**) node
- The (uniquely identified) slave responds with a **Response PDU**, typically with the same function code unless an error is reported — this results in a modified function code

Modbus RTU and ASCII employ simple (non-cryptographic) check-sums for integrity protection

- These protect against simple random bit errors only
- No confidentiality protection is provided, either

Modbus is found between field devices and PLC/RTU nodes, but also between PLCs and HMI systems

Modbus TCP

To overcome the limitations of serial links, a straightforward encapsulation over TCP/IP was realised: **Modbus TCP**

- This embeds the basic Modbus frame in a TCP packet sent normally over Port 502
- As IP may give out-of-order messages, a Transaction Identifier is used to synchronise master and slave
- Although the communication channel is implicit in the IP source and destination address, Modbus TCP still includes Unit Identifiers — these may identify multiple nodes behind gateways

Modbus TCP does not provide confidentiality, integrity (relying on TCP instead as a reliable channel), or any authentication

ISO 60870

The ISO/IEC 60870 series of standards is a SCADA standard mainly used in power systems and electrical engineering

- ISO/IEC 60870-5 (in parts -1 through -5) is mainly intended for fixed connections and describes packet formats, encodings, and transmission formats
- ISO/IEC 60870-6 in turn (in a number of sub-parts as well) is mostly intended for communication between control centres
  - The protocols are called Inter-Control Center Communications Protocol (ICCP) and evolved over different generations from **ELCOM-90** via **TASE.1** (Telecontrol Application Service Element-1) to the current **TASE.2**

These protocols themselves do not have security functionality embedded; this was added later as part of the ISO/IEC 62351 standards series

DNP3 (1)

Substantially newer than Modbus, DNP3 (Distributed Network Protocol) was developed in the early 1990s partly as a derivative of ISO/IEC 60870-5

- As with Modbus, the original protocol was for use with serial lines, but the use of TCP or UDP encapsulation is common (Port 20000)
- When used as a OSI layer 2 protocol, basic DNP3 uses CRCs for integrity protection but not cryptographic checksums
- As with Modbus, is a request-response protocol between a master and slave
  - DNP3 allows more flexibility than Modbus: Basic one-to-one links, but also multi-drop, concentrator, and hierarchical structures
- Requests and responses are embedded in short frames — DNP3 will divide longer messages into 250-byte segments

DNP3 (2)

Unlike Modbus, DNP3 is not exclusively a request–response protocol:

- Slave devices (or outstations in DNP3 terminology) may also initiate unsolicited communication to the server e.g. for alerts
- Event reporting by remote systems minimises bandwidth utilisation, and intelligent RTUs may also buffer events in different latency classes for being collected in a session and/or at different rates

DNP3 can also run over TCP and (less commonly) UDP

- For basic DNP3, encapsulation is similar to that found for Modbus, but DNP3 may also operate over UDP, providing a separate “Pseudo Transport” layer
- When using TCP as transport, the same profile as for a direct serial line is used

DNP3 Secure Authentication (1)

A common application domain for DNP3 is in power networks, mainly in North America

- With the advent of the smart grid, NERC CIP has mandated the use of security for use with DNP3 over IP, mainly requiring authentication
- This has led to the specification of **DNP3 Secure Authentication** (IEEE STD 1815-2012) nominally as a standard for Electric Power Systems Communication, sometimes simply referred to as Secure DNP3
- Secure DNP3 is a derivative of the ISO/IEC 62351-5 authentication standard (also used in other standards)

The protection is limited to (mutual) identification and authentication and integrity protection, no confidentiality is provided other than for key exchanges

DNP3 Secure Authentication (2)

To provide mutual authentication, the protocol uses asymmetric cryptography for all participants (CA, user or HMI, outstations), but must rely only on symmetric primitives for any time-sensitive operation

- Actual authentication is then achieved via a challenge-response protocol
- Backwards compatibility must be maintained, some outstations may not support authentication mechanisms
- Key management is problematic as particularly outstation asymmetric keys may not be refreshed or revoked for years (if ever)
- The protocol can distinguish between users (not only devices), giving some opportunity for auditing

In addition to the basic authentication protocol, the standard also specifies the collection of basic statistics also useful for e.g. anomaly detection (e.g. maximum number of authentication failures, reply timeouts, etc.)

ISO/IEC 61850 (1)

Somewhat in parallel to DNP3, the IEC standardisation body has developed a reference architecture for electric power systems in ISO/IEC 61850

- The communication protocols are only part of this larger model

Unlike DNP3, the ISO/IEC 61850 protocols and their predecessors were designed for high-speed networks (e.g. Ethernet, encapsulation in TCP/IP)

- Other transports such as serial links were added later and are also supported
- Since bandwidth efficiency was less important, abstract definitions of objects and services are used rather than byte-by-byte protocols; the abstract specification is mapped onto specific profiles (e.g. Ethernet or Manufacturing Messaging System, MMS)

ISO/IEC 61850 (2)

While IEC 61850 provides the same basic functionality as older protocols for queries, control, alerts, and limited file transfer mentioned before, a number of additions are in place:

- Multicasting support (e.g. for sending identical commands to groups of devices)
- Event logs
- Discovery sub-protocol for remote elements based on a logical object model
- XML-based configuration language (Substation Configuration Language)

Authentication mechanisms from ISO/IEC 62351 also used in DNP3 are applicable to ISO/IEC 61850 and 60870; this can also include implicit access control; explicit sub-standards exist for several ISO/IEC 61850 profiles

ISO/IEC 61850 (3)

ISO/IEC 61850 assumes the presence of a cyptographic base layer (SSL/TLS) for integrity and confidentiality protection.

- Actual security measures are defined in ISO/IEC 62351-6
- As with any SSL/TLS communication, the establishment of a session relies on asymmetric cryptography and is hence time-consuming.
- Some exceptions to the use of enryption exist, some not allowing

ISO/IEC 61850 also enforces an *identity-based* acces control model, giving restricted access to logical nodes (also known as a *virtual view*)

- Any failed attempts are logged together with other anomalies

OPC (1)

Originally developed in the mid-1990s under the name Object Linking and Embedding (OLE) for Process Control, OPC has been re-named in 2011 as Open Platform Communications

- Intended as a way of using Windows-based systems for accessing process control hardware
- Devices such as PLCs can implement OPC servers providing several services, mainly the OPC Data Access service used for (near) real-time data
- Other services include OPC Historical Data Access used for data that is not representing the current state, and OPC Alarms and Events where asynchronous notifications are required

The original name derives from the use of the Microsoft OLE (also referred to as the Microsoft Common Object Model (COM) or Distributed COM (DCOM)

OPC (2)

OPC defined objects, interfaces, and access methods for process control systems

- Some of the specifications were made public, others are available only to the members of a consortium
- Microsoft itself has deprecated COM/DCOM subsequently; this model had proven to be complex, difficult to configure, and is proprietary to Microsoft only, very limited control over time-outs
- Severe security issues, partly based on configuration complexity, partly on implementation complexity
- Based on this, OPC started supporting a XML-based encoding rather than the proprietary Microsoft COM/DCOM model beginning in 2003

Note that OPC is providing anything but strictly deterministic real-time behaviour!

OPC Unified Architecture (1)

Although the OPC XML-DA provided some separation from the deep embedding into the Microsoft platform that COM/DCOM implied, it still relied heavily on Microsoft .NET in addition to open standards (XML, SOAP, WSDL)

OPC Unified Architecture (IEC 62541) from 2006 onwards (current: 2011) seeks to address this

- Two protocols are supported, one based on a binary protocol not using XML/SOAP, and one based on web services (XML/SOAP-based)
- UA Security provides identification and authentication (as well as access control based on this service) along with confidentiality and integrity
- Authentication relies on public key cryptography (based on X.509 certificates); similarly integrity is provided via digital signatures
- OPC UA can even rely on an existing Active Directory public key infrastructure

OPC Unified Architecture (2)

The binary variant of the OPC UA similarly relies on the security primitives found in web services such as WS-SecureConversation, but transforms these to a binary equivalent

OPC (in all its incarnations) provides rather greater attack surfaces based on the complexity of the implementation

- Consider the number of protocols and dependencies involved — particularly lines of code
- OPC (including UA) relies on a number of operating system services that may be difficult to validate: In the DCOM variant security was controlled by Windows user accounts!
- Although OPC UA is not platform-dependent, there is an implicit assumption that a Microsoft Windows gateway is used or the PLC itself runs some variant of Microsoft Windows

Summary

This section provided material on

- Supervisory Control and Data Acquisition (SCADA) architectures
- Distributed Control Systems
- Control System Protocols